

Cybersecurity requirements for Virtual Private Networks

Deep Dive Session

EN 304 620

Presented by: Aki Rose Braun
January 2026



Agenda

Session Overview

- CRA & Standardisation Request Overview
- STAN4CR2 Project Context
- Standard Scope & Document Structure

Deep Dive Content

- Use cases
- Annex C, risk assessment
- Technical Requirements (Clause 5)
- Assessment criteria
- Areas for Stakeholder Feedback

CRA & Standardisation Request Overview

Cyber Resilience Act Purpose

- CRA ensures products with digital elements are secure by design and resilient against cyber threats throughout their lifecycle.

Key Focus for VPNs

- Unrelated to specific features, focus on cybersecurity requirements

Harmonized Standards Benefits

- Reduce market fragmentation and help manufacturers efficiently meet regulatory expectations across the EU.
- Ensuring products are secure by design
- Identifying and mitigating vulnerabilities

STAN4CR2 Project Context

Harmonized Standards Development

- STAN4CR2 focuses on creating cybersecurity standards for different vertical products with digital elements to ensure CRA compliance.

Organizational Leadership and Funding

- ETSI leads the project through its CYBER-EUSR technical group, working jointly with CEN CENELEC (JTC13/WG9), with funding from the European Commission and EFTA.

Collaborative Approach

- The project fosters collaboration amongst industry, regulators, and academia to address cybersecurity challenges and align with EU regulations.

ETSI EN 304 620 Scope

Product Coverage

- Consumer VPNs with manufacturer-hosted exit nodes
- Mesh VPNs
- Enterprise VPNs

CRA Classification: Class I products under Annex III, point 5

Out of Scope

- “Zero trust network architecture” products
- other firewall-like devices that offer some VPN-like features

Product Context (Clause 4)

Intended purpose, Essential functions, & Architecture (4.1–4.3)

- Provides more thorough detail on the products covered by this document and their composition

Operational environment & Distribution of security functions (4.4–4.5)

- Describes the physical and digital environment in which the VPN functions
- Lays out how that environment is responsible for certain security functions
- Addresses security functionality for child components

Users & Use Cases (4.6–4.7)

- Product use scenarios with differing security needs

Clause 5: Requirements specifications

- Lists all threats identified by the standard and mitigations for those threats
- Manufacturers shall complete a risk assessment to understand which mitigations they are required to apply

Risk identification and assessment methodology (Annex C)

- Risk Factors (C.2) — Manufacturers evaluate identified risks based on intended purpose, foreseeable use, and conditions of use
- Risk Factor Assessment (C.4) — Use those risks to enumerate threats and, based on the evaluated risks, which mitigations are required to lower likelihood and impact of an incident
- Understanding use cases (C.5) — A mapping of risk factors for use cases described in 4.7

Result

- Each threat has one or more mitigations to lower risk level, those mitigations are the listed requirements in Clause 5

Understanding risk assessment and use cases

- Use cases provide pre-packaged threat and mitigation identification
- For use cases not described in the standard, determining mitigation requirements is straightforward

Process

- For each *risk factor*, manufacturer determines which level applies to their product and use case
- For each *threat*, manufacturer determines the likelihood and impact based on level of previously identified *risk factor*
- Manufacturer applies appropriate *requirements* to mitigate risk

Lowering risk levels

Every risk must be mitigated

- Most commonly, this will be by identifying mitigations which lower risk to an acceptable amount
- Some risks are mitigated by delegating to the operating environment, or to the user via clear documentation

Only the requirements associated with a given threat are mandatory

Risk Factors identified in Annex C

C.2.2 RF-CFG: End-point configuration

Affects likelihood of threats involving misconfiguration.

C.2.3 RF-AUT: Account management and authentication of endpoints

Affects likelihood of threats involving authentication.

C.2.4 RF-DAT: Sensitivity of data

Affects impact of threats involving loss of data confidentiality, availability, or integrity.

C.2.5 RF-FUN: Sensitivity of functions

Affects impact of threats involving loss of availability of product functions.

Risk Factors identified in Annex C (cont)

C.2.6 RF-ADM: Availability of administration

What the availability and skill of administration is for the product.

C.2.7 RF-RDP: Manufacturer infrastructure isolation

Exposure of manufacturer infrastructure responsible for essential functions of the product

C.2.8 RF-DNC: Difficulty of network configuration

Difficulty of configuring, controlling, and monitoring the configuration of the network connection on the platform the product is running on.

Risk Factors identified in Annex C (cont)

C.2.9 RF-COM: Complexity of feature set

How complex the features necessary for the product's foreseeable use are.

C.2.10 RF-CON: Connectivity offered

Whether the VPN connects different endpoints to each other via a private network or simply provides a tunnel from a single endpoint to a public network

C.2.10 RF-PII: Consequences of personally identifiable information compromise

What the consequences of an attacker acquiring PII via the product are.

Other risk assessments

- Annex C is informative and not required
- Completing and clearly documenting a risk assessment *is* required

Requirement Overview (Clause 5)

Requirements are grouped by *threat*, with one or more *mitigation*

- C.4.3 TH-UEVU: Unknown exploitable vulnerabilities
- C.4.4 TH-KEVU: Known exploitable vulnerabilities
- C.4.5 TH-UEAC: Unauthorised endpoint access
- C.4.6 TH-RDOS: Denial of service on remote data processing
- C.4.7 TH-MITM: Machine-in-the-middle
- C.4.8 TH-LEAK: Sensitive data leaks
- C.4.9 TH-PLNS: Transmitting sensitive data in the clear in a single endpoint VPN
- C.4.10 TH-PLNM: Transmitting sensitive data in the clear in multi-endpoint VPN
- C.4.11 TH-UNAA: Unauthorised authentication

Requirement Overview (Clause 5) (cont)

Requirements are grouped by *threat*, with one or more *mitigation*

- C.4.12 TH-LDEL: Attacker removes evidence of compromise
- C.4.13 TH-CNFS: Access to assets via configuration errors in single endpoint VPN
- C.4.14 TH-CNFM: Access to assets via configuration errors in a multi-endpoint VPN
- C.4.15 TH-META: Compromise of PII due to metadata and traffic analysis
- C.4.16 TH-RCOM: RDPS compromise and isolation
- C.4.17 TH-USED: Access to data via access to used product
- C.4.18 TH-CPPI: Compromise of PII stored or transmitted by the product

Assessment Procedure Structure

Each requirement includes clear testing criteria:

- Requirement Statement
- Activities - Step-by-step verification: review documentation, examine config, test functionality
- Verdict - Clear pass/fail criteria
- Supporting Evidence - Required documentation: manufacturer docs, configuration files, test results, log entries

Assessment Example: No traffic through the node unless explicitly approved

MI-TRAF-1: No capability to route traffic from other sources

Activities:

- Connect an endpoint and capture the traffic on all interfaces

Verdict:

- PASS: No traffic originating from the VPN for sources/destinations other than the endpoint
- FAIL: VPN traffic identified routing to somewhere other than the endpoint

Key Principles

Design Philosophy

- Each requirement analysed for feasibility - implementation costs considered
- Risk factors create natural consequences
- Standard allows product diversity - simple products face fewer and less complex conditional requirements
- Requirements are objective and testable - third-party assessors can verify consistently

Areas Requiring Stakeholder Feedback

Your input is critical for:

- Risk factor completeness - additional product vulnerabilities to address?
- Requirement feasibility - implementable and cost-effective?
- Assessment procedures - verification methods clear and executable?
- Cross-vertical alignment - common approaches for cryptography, updates, SBOM, auth
- Product scope boundaries - clear managed vs unmanaged distinction

No clause is written in stone - all may be improved based on industry expertise.

How to Participate

Access Draft Documents

- ETSI Open Area: <https://docbox.etsi.org/CYBER/EUSR/Open>

Collaborative Technical Discussion

ETSI Labs: <https://labs.etsi.org/rep/stand4cra/en-304-620-1/-/issues>

Active Stakeholder Engagement

- Submit comments and propose improvements
- Engage in debates to refine standards
- Participate in open consultations

Q&A





Thank you for your attention!



Co-funded by
the European Union

Follow us on:

